Faso Cikan : note de pré-projet

Messagerie souveraine de l'administration · Hackathon 226, sprint technique 2026 Équipe : [nom de l'équipe] · [université ou établissement]

Le concept

Faso Cikan est une messagerie instantanée pour les agents de l'administration burkinabè. Elle s'installe sur un serveur de l'État et ne dépend d'aucun service extérieur. Un agent s'y connecte avec son matricule de la fonction publique, son mot de passe et un code à usage unique. Son identifiant de messagerie est tiré du matricule (@318264b:faso.gov.bf) : pas de numéro de téléphone, pas d'inscription libre, et seule l'autorité peut enrôler un agent ou lui retirer l'accès. Toute l'interface est en français.

Nous ne sommes pas partis d'une page blanche, et le règlement nous interdit d'écrire notre propre cryptographie. Nous avons pris Matrix, qui a fait ses preuves, et nous lui avons ajouté ce qui manque à une administration : une identité d'État, des niveaux de classification et un pouvoir de révocation.

Protocole de chiffrement

Composant	Version	Licence	Projet
Synapse	1.163.2	AGPL-3.0	github.com/element-hq/synapse
Element Web	1.12.32	AGPL-3.0	github.com/element-hq/element-web

matrix-js-sdk	44.0.0	Apache-2.0	github.com/matrix-org/matrix-js-sdk
Keycloak	26.7.5	Apache-2.0	github.com/keycloak/keycloak

Matrix, avec Olm entre les appareils et Megolm dans les salons, tels que les implémente matrix-js-sdk. Nous n'avons écrit aucune cryptographie. Les salons sont chiffrés par défaut, et un module que nous avons ajouté à Synapse refuse tout message envoyé en clair (erreur 403). Le serveur ne garde donc que du texte chiffré.

Architecture

Six conteneurs, lancés ensemble par Docker Compose. Seul Caddy ouvre des ports (80 et 443), tout le reste reste sur un réseau interne.

Service	Rôle
Caddy	point d'entrée unique, HTTPS, en-têtes de sécurité
Element Web	client web : c'est là que les messages sont chiffrés et déchiffrés
Synapse + module faso_cikan	serveur Matrix ; notre module impose le chiffrement et gère la classification
Keycloak	identité, second facteur (code à usage unique), rôles
PostgreSQL	les bases de Synapse et de Keycloak
Console (FastAPI)	enrôlement, révocation, journal d'audit

Synapse ne vérifie jamais un mot de passe lui-même : il renvoie l'agent vers Keycloak (OpenID Connect) et n'accepte que les comptes qui portent le rôle « agent ». La console pilote Keycloak et Synapse par leurs API d'administration, qui ne sont jamais exposées hors du réseau interne.

Composants open source

Composant	Version	Licence	Projet
PostgreSQL	16	Licence PostgreSQL	postgresql.org
Caddy	2.10	Apache-2.0	github.com/caddyserver/caddy
FastAPI		MIT	github.com/fastapi/fastapi
Docker Compose		Apache-2.0	github.com/docker/compose

Présentation : police Work Sans (SIL OFL 1.1), icônes Phosphor (MIT), logos Simple Icons (CC0).

Niveau d'engagement : étendre et adapter

Nous partons d'Element Web et de Synapse sans les recopier. Nos ajouts vivent dans deux dossiers (`element/src/faso/` et `synapse/modules/faso_cikan/`). Dans Element lui-même, nous ne touchons que ce qu'il faut pour brancher nos ajouts : environ 40 lignes sur 10 fichiers, plus 9 lignes dans le SDK. Notre code est publié sous AGPL-3.0, comme les projets dont il dérive. Nous n'avons pas encore soumis de contribution aux projets d'origine.

Ce que nous ajoutons

Classification des messages. Un message peut être marqué « Diffusion restreinte » ou « Confidentiel ». Il ne peut plus être transféré ni modifié, et l'expéditeur fixe une échéance, de 30 secondes à 7 jours. À l'échéance, c'est le serveur qui l'efface sur tous les appareils, sans l'avoir jamais lu : l'étiquette voyage en clair à côté du texte chiffré, et c'est tout ce qu'il voit.

Révocation immédiate. Depuis la console ou en ligne de commande, l'autorité coupe un agent en une seule action : compte Keycloak désactivé, sessions fermées, compte Matrix désactivé, appareils déconnectés, sortie de tous les salons. L'opération est inscrite dans un journal d'audit.

Enrôlement par l'autorité. Elle crée le compte et remet un mot de passe provisoire. À sa première connexion, l'agent choisit le sien et active son second facteur.

Moins de métadonnées. Pas de présence en ligne, adresses IP gardées un jour, pas d'aperçu de liens, messages supprimés purgés de la base au bout d'une minute.

Tests

Vingt-six tests de bout en bout passent par les vraies adresses HTTPS : connexion avec second facteur, chiffrement obligatoire, révocation en pleine conversation, compte non enrôlé rejeté, effacement réel d'un message confidentiel. Un scénario joué dans un vrai navigateur les complète.

Répartition des rôles

- BANHORO Basséri Arcélia & Doamba beatrice samdubwaoga : serveur et sécurité (Keycloak, module
- Synapse, console, déploiement).

  RUFAI SARATOU: client (Element, classification, interface, page d'accueil).